

Vendor Security Policy

Sample reference policy for testing the Verity compliance knowledge base

1. Purpose

This policy defines the minimum security and privacy requirements for third-party vendors that access company systems or process company, employee, customer, or personal data.

2. Data Protection

Vendors must process personal data only for documented business purposes, follow applicable data protection laws, restrict access to authorized personnel, and maintain confidentiality obligations for all personnel with access to data.

3. Security Controls

Vendors must use encryption in transit and at rest, multi-factor authentication for privileged access, least-privilege access controls, secure backups, malware protection, vulnerability management, and annual security training.

4. Incident and Breach Notification

The vendor must notify the company within 24 hours after discovering a suspected or confirmed security incident or personal data breach. The notification must include the affected systems, data categories, timeline, containment actions, and a contact for continued coordination.

5. Subprocessors

Vendors must obtain written approval before appointing a subprocessor that will access company data. The vendor remains responsible for the acts and omissions of its subprocessors.

6. Data Retention and Deletion

At the end of the services, or earlier upon written request, the vendor must return or securely delete company data and provide written confirmation of deletion, subject to legally required retention.

7. Audit and Evidence

The company may request reasonable evidence of compliance, including security certifications, policies, penetration-test summaries, and remediation status. Vendors must cooperate with a reasonable security review.

8. Business Continuity

Vendors must maintain tested business-continuity and disaster-recovery procedures appropriate to the services and must notify the company of material disruptions.

9. Minimum Contract Requirements

Vendor agreements should include confidentiality, data-processing responsibilities, breach notification timelines, audit rights, subcontractor controls, data deletion, liability allocation, governing law, and termination rights.

Document owner: Compliance and Information Security | Version: 1.0 | Status: Sample